



**HOGESCHOOL
UTRECHT**



AANVALSSCENARIO



Namen: Cailyn Huwae & Ali Othman
Studenten nummers : 1898599 & 1860574

Juni 01, 2025
P2_Aanvalsscenario

Index

- Samenwerking _____ 3
- Scenario _____ 3
- Aanvalsopzet _____ 3
- Technische details _____ 4

Samenwerking

Dit scenario is ontwikkeld en wordt uitgevoerd door Ali Othman en Cailyn Huwae als onderdeel van een gezamenlijke opdracht. Samen vormen wij een team dat een gesimuleerde ransomware-aanval en Man-in-the-Middle (MITM) voorbereidt. Cailyn is verantwoordelijk voor Man-in-the-Middle (MITM), terwijl Ali zich richt op het uitvoeren van de ransomware-aanval.

Scenario

Een middelgroot bedrijf bevindt zich in de voorbereidingsfase voor een compliance-certificering (bijv. ISO 27001). In dit kader wil het management de digitale weerbaarheid van de organisatie testen, specifiek op het gebied van Man-in-the-Middle (MITM), ransomware en menselijke fouten.

Onze groep speelt hierin de rol van een interne red-team die een gesimuleerde aanval uitvoert.

Aanvalsopzet

- MITM-aanval op lokaal netwerk
- Zodra de gebruiker een bekende downloadsite probeert te bezoeken (zoals zoom.com), wordt omgeleid naar een door ons gehoste website
- In de mail zit een link naar een externe (door ons gehoste).
- Op die website wordt een ZIP-bestand aangeboden met een zogenaamd installatiebestand (.exe). In werkelijkheid bevat dit bestand een simulatie van ransomware of een ongevaarlijk dummy-script dat een waarschuwing toont ("U bent slachtoffer geworden van een gesimuleerde aanval.").

Technische details

- Via Bettercap wordt een MITM-aanval uitgevoerd om verkeer tussen een slachtoffer en de router te onderscheppen.
- React-gebaseerde phishingpagina, die eruitziet als een officiële pagina van het bedrijf.
- Op de website staat een ZIP-bestand klaar met daarin een .exe-bestand dat als simulatie van ransomware fungeert.

- Over de .exe ransomware-simulatie
 - Het .exe-bestand is volledig zelf ontwikkeld in Python.
 - De applicatie heeft een eenvoudige grafische gebruikersinterface (GUI) waarmee de “slachtoffer” zogenaamd kan interacteren
 - Zodra het slachtoffer de .exe opent, worden automatisch bepaalde bestanden op het systeem versleuteld (alleen demo-bestanden in een testmap, géén echte schade).
 - Het script is gekoppeld aan een real-time database waarin automatisch de encryptiesleutel wordt opgeslagen zodra de aanval wordt geactiveerd.
 - De belangrijke functies zijn:
 - Encrypt: start het versleutelingsproces van bestanden (simulatie).
 - Decrypt: is alleen beschikbaar met de juiste sleutel, die zogenaamd via “betaling” of “IT contact” verkregen moet worden.
 - De gebruiker krijgt een waarschuwingsscherm te zien waarin staat dat de bestanden zijn versleuteld, met instructies om contact op te nemen net als bij een echte ransomware-aanval.